

IBS: Bezpečnost a počítačové sítě

Authentication, Authorization, Accounting

Brno University of Technology, Faculty of Information Technology

Božetěchova 1/2, 612 66 Brno - Královo Pole

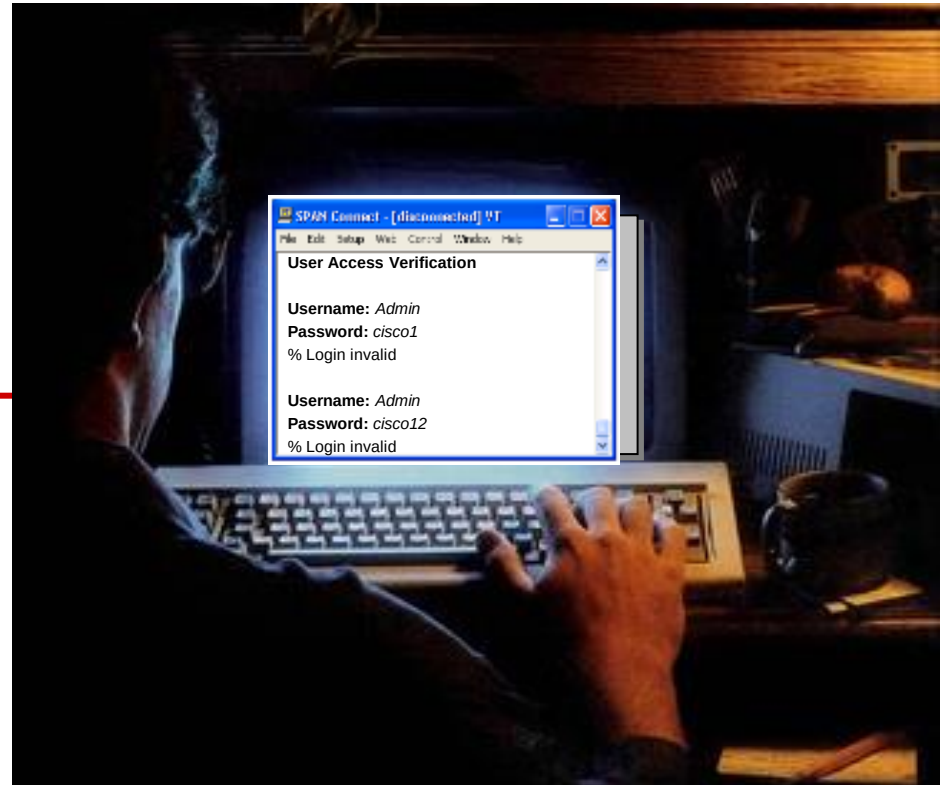
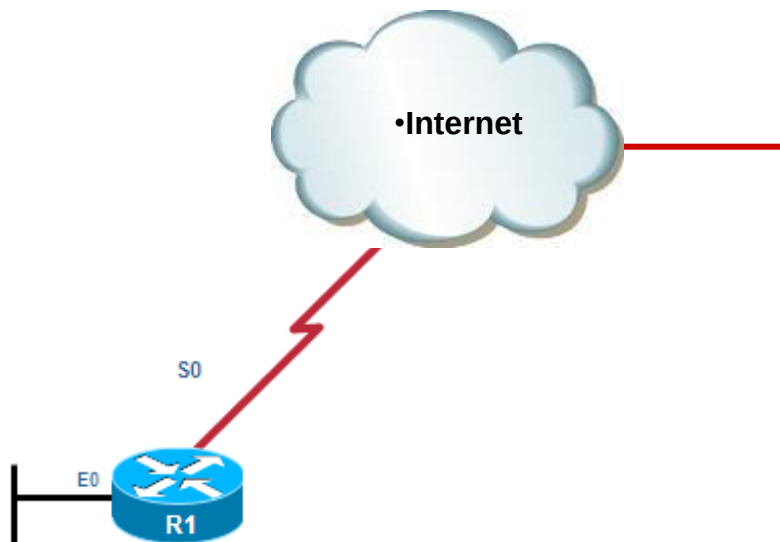
Vladimír Veselý, veselyv@fit.vut.cz

Matěj Grégr, mgregr@fit.vut.cz



16th April 2026

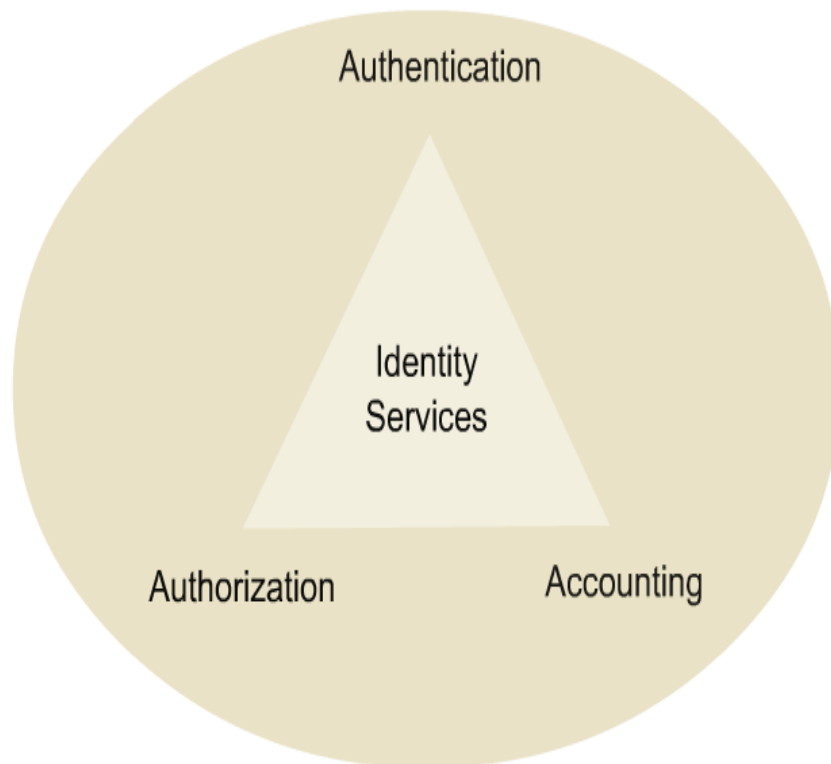
SERVER-BASED AAA



```
R1(config)# username Admin secret Str0ng5rPa55w0rd
R1(config)# line vty 0 4
R1(config-line)# login local
```

- It provides greater security than a simple password.
- It's a cost effective and easily implemented security solution.

- The problem is this local database has to be replicated on several devices!
 - A better scalable solution is to use AAA



Authentication - Who is allowed access?



Authorization - What are they allowed to do?



Accounting - What did they do?

Authentication

Who are you?



Authorization

How much can you spend?

Statement of Personal Credit Card Account

Cardmember Name: JOE EMPLOYEE Account Number: 1234-456-890 Statement Closing Date: 01-31-01

Statement Date: 02-01-01 Payment Due Date: 03-01-01

Closing Date: 01-31-01

Credit Limit: \$1,500.00 Credit Available: \$1,221.50

New Balance: \$278.50 Minimum Payment Due: \$20.00

Account Summary

Previous Balance:	+74.24	Transaction Fees:	+3.00
Purchases:	+250.50	Annual Fees:	+25.00
Cash Advances:	+0	Current Amount Due:	+250.50
Payments:	-74.25	Amount Past Due:	+0
Finance Charge:	+0	Amount Over Credit Line:	+0
Late Charge:	+0	NEW BALANCE:	\$278.50

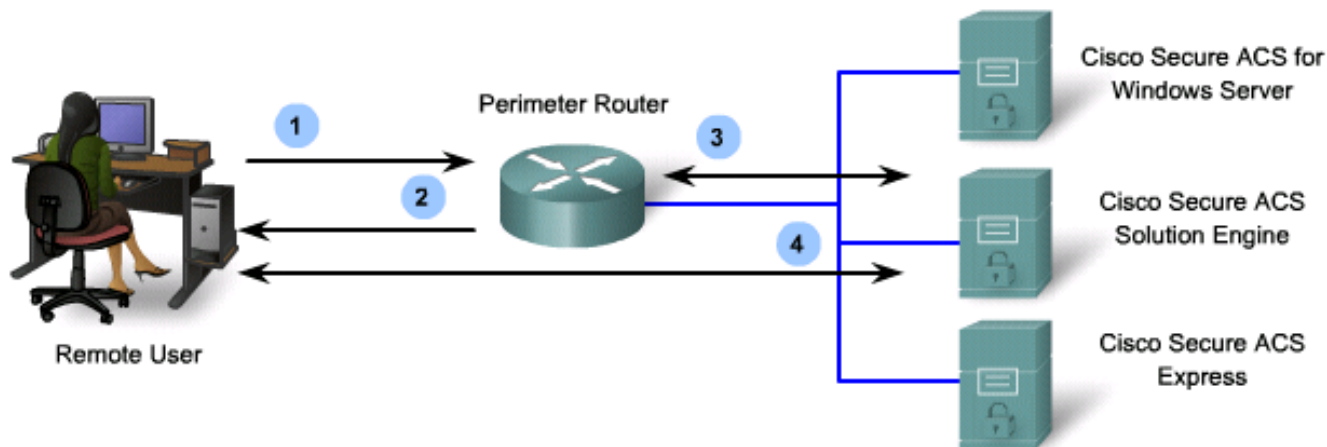
Reference Number	Sold	Posted	Activity Since Last Statement	Amount
43210987	01-03	01-13	Payment, Thank You	-\$74.25
01234567	01-12	01-13	Wings N' Things Anytown, USA	\$25.25
78901234	01-14	01-17	Record Release Anytown, USA	\$40.00
45678901	01-14	01-17	Sports Stadium Anytown, USA	\$75.25
3210987	01-22	01-23	Tie Tack Anytown, USA	\$20.75
76543210	01-29	01-30	Electronic World Anytown, USA	\$89.25
23455678		01-30	Transaction Fees	\$3.00
34567890		01-01	Annual Fee	\$25.00

PAGE 1 OF 1

Accounting

What did you spend it on?

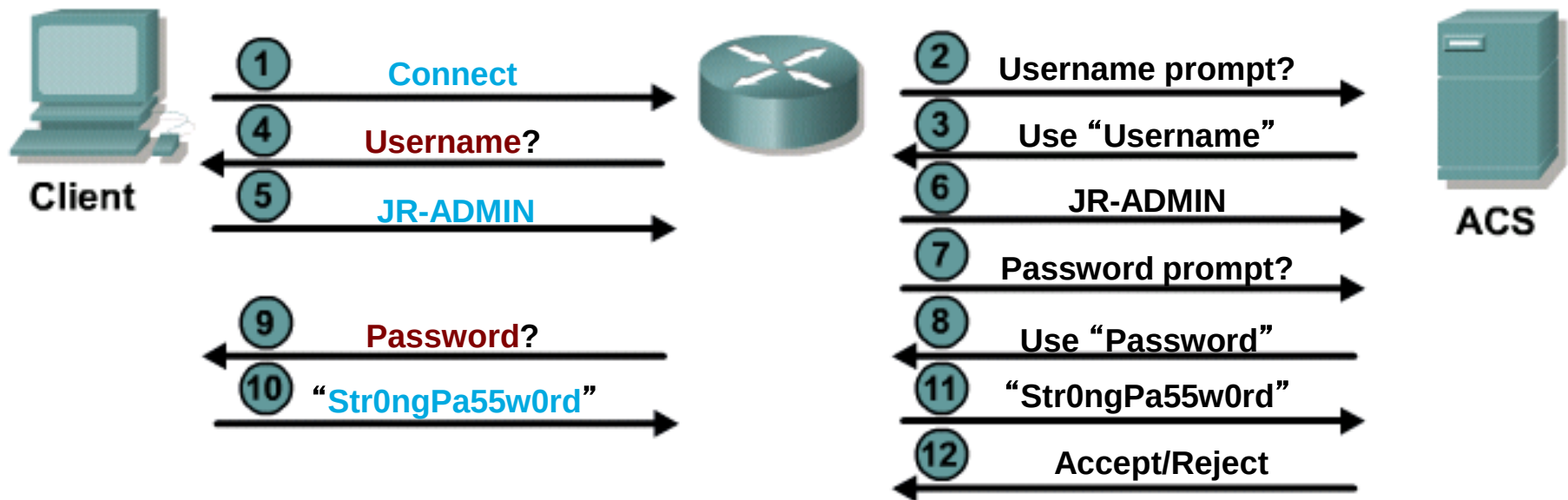
- Protocols
 - Terminal Access Control Access Control Server Plus (TACACS+)
 - **Remote Dial-in User Services (RADIUS)**
- Both protocols can be used to communicate between client and AAA servers.



Server-Based Authentication

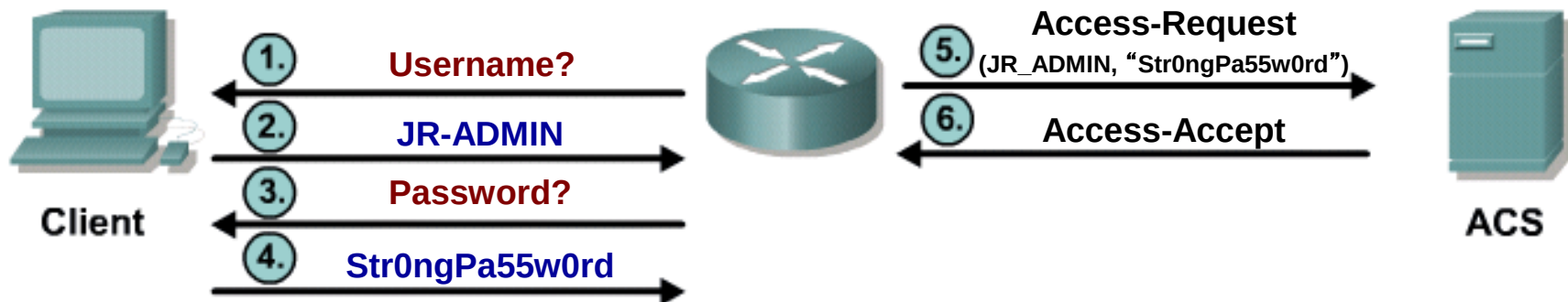
1. The user establishes a connection with the router.
2. The router prompts the user for a username and password.
3. The router passes the username and password to the Cisco Secure ACS (server or engine).
4. The Cisco Secure ACS authenticates the user. The user is authorized to access the router (administrative access), or the network based on information found in the Cisco Secure ACS database.

- TACACS+ is a Cisco protocol that provides separate AAA services.
 - Separating the AAA services provides flexibility in implementation, because it is possible to use TACACS+ for authorization and accounting while using another method of authentication.



- RADIUS, developed by Livingston Enterprises, is an open IETF standard AAA protocol for applications such as network access or IP mobility.
 - RADIUS is currently defined by RFCs 2865, 2866, 2867, and 2868.
- The RADIUS protocol hides passwords during transmission but the rest of the packet is sent in plaintext.

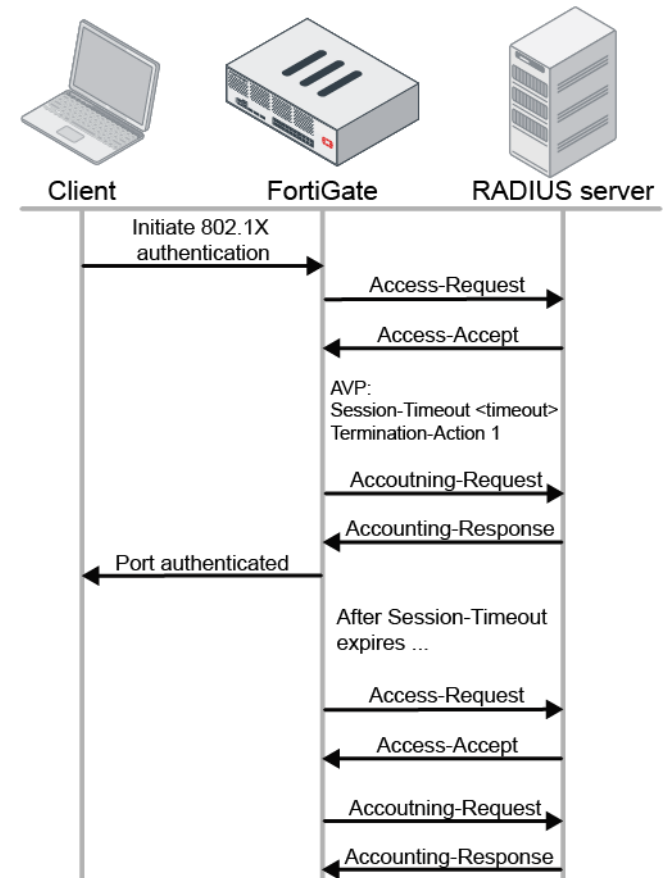
- RADIUS combines authentication and authorization as one process which means that when a user is authenticated, that user is also authorized.
 - RADIUS uses UDP port 1645 or 1812 for authentication and UDP port 1646 or 1813 for accounting.



Loopback: lo0

No.	Time	Source	Destination	Protocol	Length	Info
112	54.568848	127.0.0.1	127.0.0.1	RADIUS	80	Access-Request id=30
153	58.601007	127.0.0.1	127.0.0.1	RADIUS	52	Access-Reject id=30
1133	396.725095	127.0.0.1	127.0.0.1	RADIUS	80	Access-Request id=31
1140	400.620504	127.0.0.1	127.0.0.1	RADIUS	52	Access-Reject id=31

▶ Frame 1133: 80 bytes on wire (640 bits), 80 bytes captured (640 bits) on interface lo0, id 0
 ▶ Null/Loopback
 ▶ Internet Protocol Version 4, Src: 127.0.0.1, Dst: 127.0.0.1
 ▶ User Datagram Protocol, Src Port: 50878, Dst Port: 1812
 ▼ RADIUS Protocol
 Code: Access-Request (1)
 Packet identifier: 0x1f (31)
 Length: 48
 Authenticator: df3e0d0fb6a1eac9188bd80b2ba1a992
 [\[The response to this request is in frame 1140\]](#)
 ▼ Attribute Value Pairs
 ▶ AVP: t=User-Name(1) l=10 val=testuser
 ▶ AVP: t=User-Password(2) l=18 val=Decrypted: \376t/z\223p\256\377p\340\222\263Pini

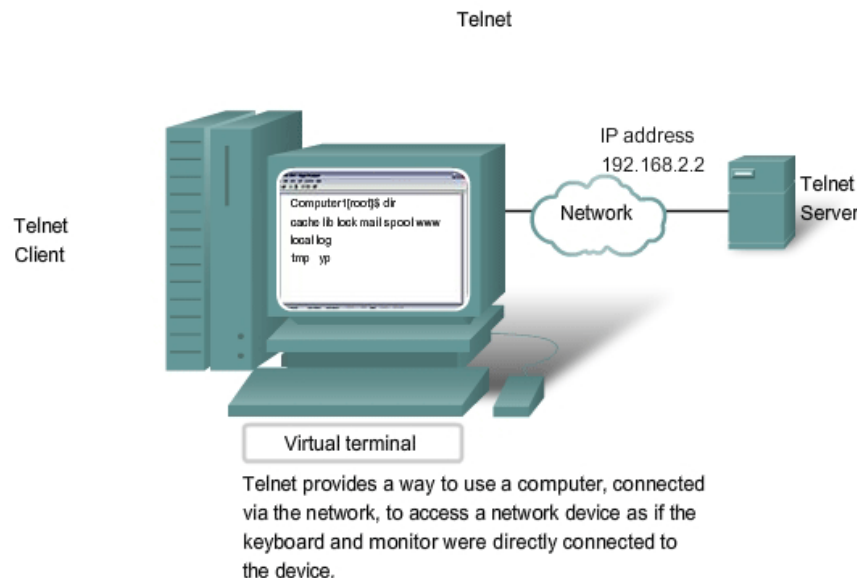


- RADIUS is widely used by VoIP service providers because it passes login credentials of a session initiation protocol (SIP) endpoint, such as a broadband phone, to a SIP Registrar using digest authentication, and then to a RADIUS server using RADIUS.
 - **RADIUS is also a common authentication protocol that is utilized by the 802.1X security standard.**
- The DIAMETER protocol is the planned replacement for RADIUS.
 - [RFC 6733](#)
 - DIAMETER uses a new transport protocol called Stream Control Transmission Protocol (SCTP) and TCP instead of UDP.

Feature	TACACS+	RADIUS
Functionality	Separates AAA according to the AAA architecture, allowing modularity of the security server implementation	Combines authentication and authorization but separates accounting, allowing less flexibility in implementation than TACACS+.
Standard	Mostly Cisco supported	Open/RFC standard
Transport Protocol	TCP port 49	UDP port 1645 or 1812 for authentication UDP port 1646 or 1813 for accounting
CHAP	Bidirectional challenge and response as used in CHAP	Unidirectional challenge and response from the RADIUS security server to the RADIUS client.
Protocol Support	Multiprotocol support	No ARA, no NetBEUI
Confidentiality	Entire packet encrypted	Only the password is encrypted
Customization	Provides authorization of router commands on a per-user or per-group basis.	Has no option to authorize router commands on a per-user or per-group basis.
Accounting	Limited	Extensive

REMOTE ACCESS

- RFC 854
- Bidirectional 8bit communication channel
- TCP on port 23
- NVT (Network Virtual Terminal) – imaginary virtual terminal shared by both communicating parties

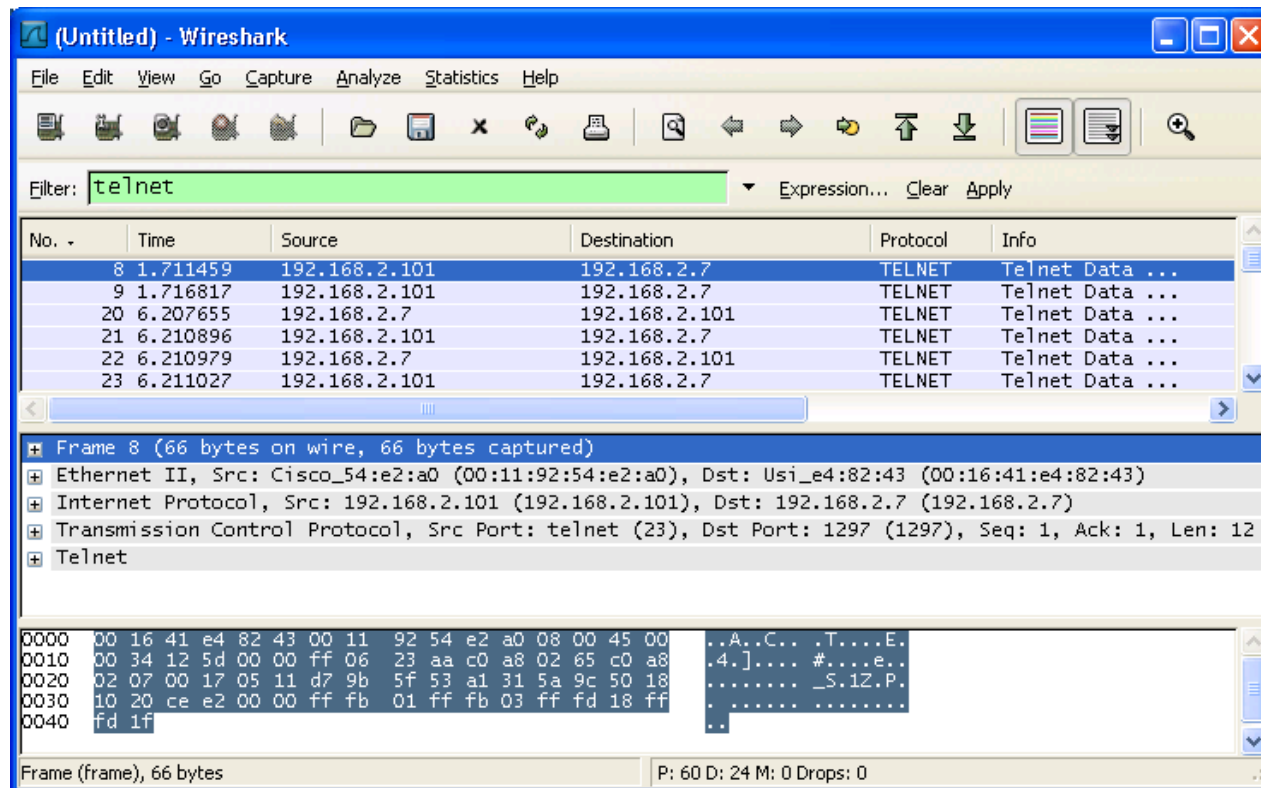


Description	Decimal Code	Action
WILL	251	Sender wants to do something.
WONT	252	Sender doesn't want to do something.
DO	253	Sender wants the other end to do something.
DONT	254	Sender wants the other not to do something.

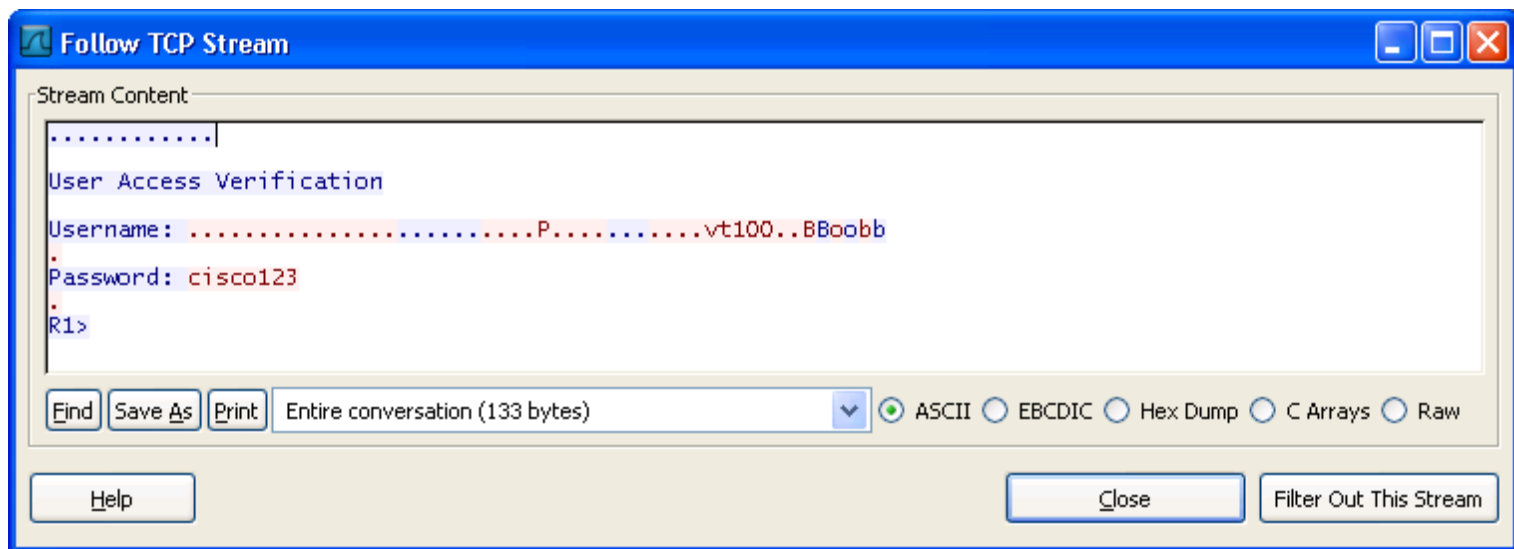
Sender Sent	Receiver Responds	Implication
WILL DO	The sender would like to use a certain facility if the receiver can handle it.	Option is now in effect.
WILL DONT	Receiver says it cannot support the option.	Option is not in effect.
DO WILL	The sender says it can handle traffic from the sender if the sender wishes to use a certain option.	Option is now in effect.
DO WONT	Receiver says it cannot support the option.	Option is not in effect.
WONT DONT	Option disabled.	DONT is only valid response.
DONT WONT	Option disabled.	WONT is only valid response.

Name	Decimal Code	Meaning	Comment
SE	240	End of subnegotiation parameters	
NOP	241	No operation	
DM	242	Data mark	Indicates the position of a Synch event within the data stream. This should always be accompanied by a TCP urgent notification.
BRK	243	Break	Indicates that the "break" or "attention" key was hi.
IP	244	Suspend	Interrupt or abort the process to which the NVT is connected.
AO	245	Abort output	Allows the current process to run to completion but does not send its output to the user.
AYT	246	Are you there	Send back to the NVT some visible evidence that the AYT was received.
EC	247	Erase character	The receiver should delete the last preceding undeleted character from the data stream.
EL	248	Erase line	Delete characters from the data stream back to but not including the previous CRLF.
GA	249	Go ahead	Under certain circumstances used to tell the other end that it can transmit.
SB	250	Subnegotiation	Subnegotiation of the indicated option follows.
WILL	251	will	Indicates the desire to begin performing, or confirmation that you are now performing, the indicated option.
WONT	252	wont	Indicates the refusal to perform, or continue performing, the indicated option.
DO	253	do	Indicates the request that the other party perform, or confirmation that you are expecting the other party to perform, the indicated option.
DONT	254	dont	Indicates the demand that the other party stop performing, or confirmation that you are no longer expecting the other party to perform, the indicated option.

- An attacker is capturing packets using Wireshark on a local subnet.
- The attacker is interested in TCP Telnet streams and notices that the administrator's IP address (192.168.2.7) has initiated a Telnet session to a device.

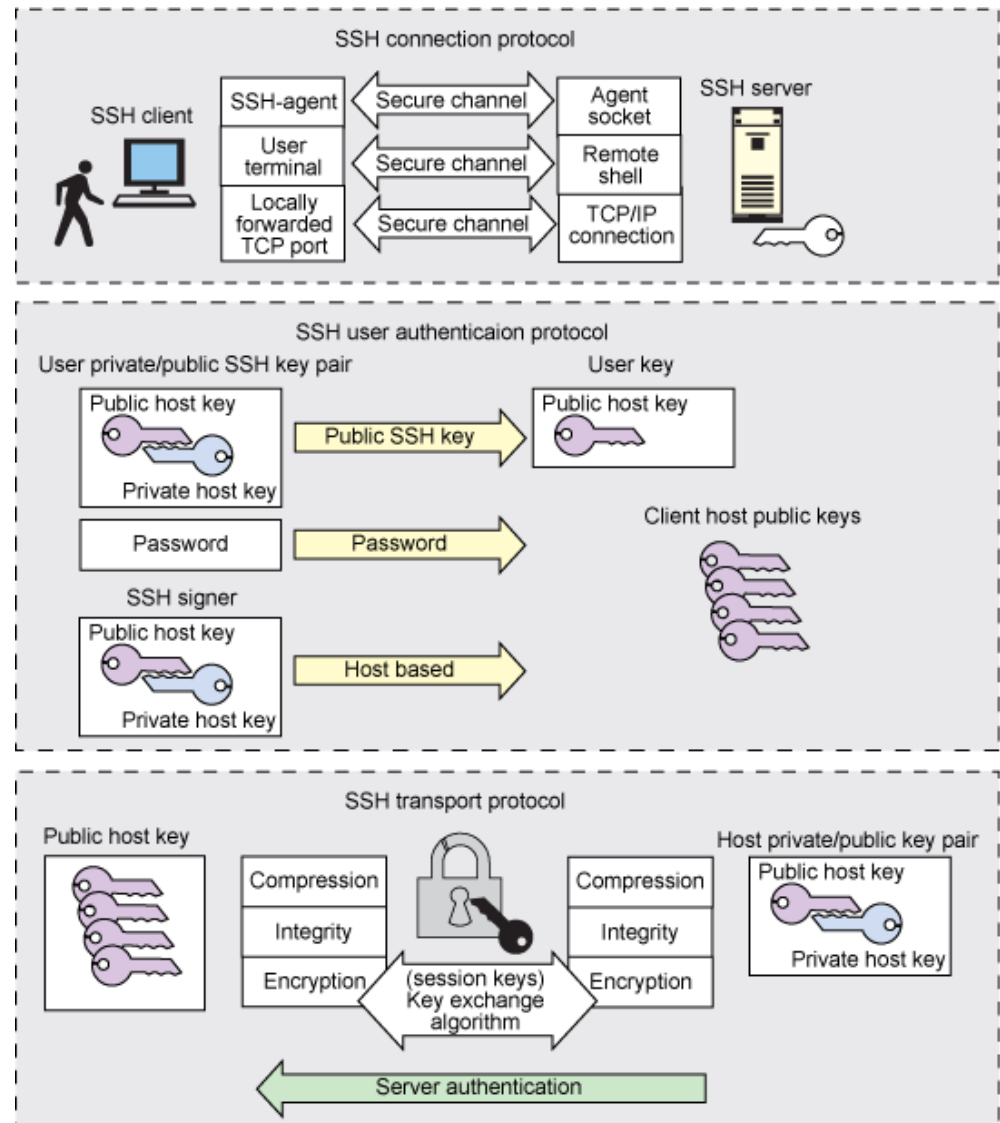
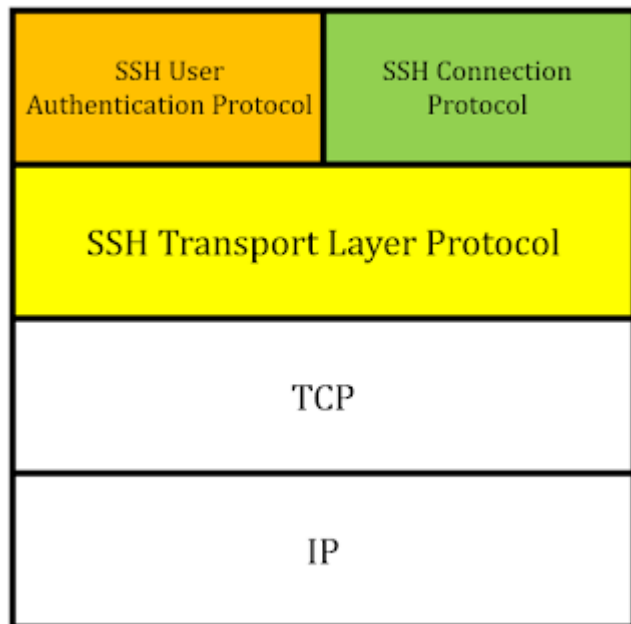


- By following the TCP Telnet stream, the attacker has captured the administrator's username (Bob) and password (cisco123).

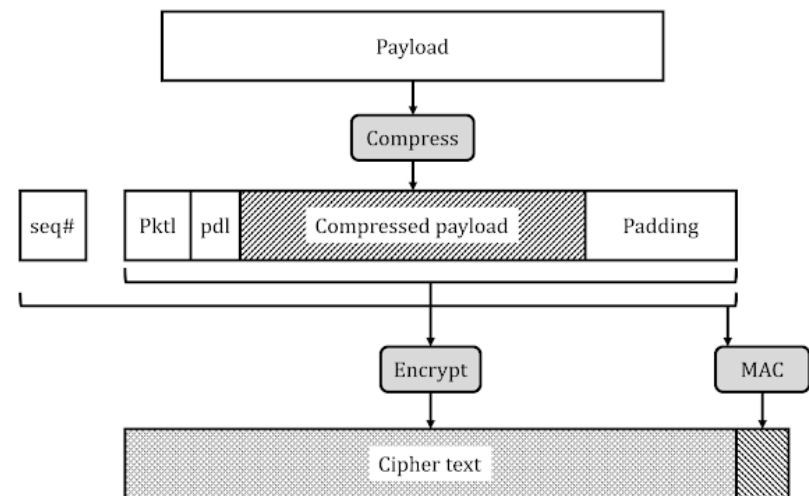


- [RFC 4251](#), 4252-4254
- SSH establish a secure channel over an insecure network in a client-server architecture
- Replaces unsecure remote control protocols such as Telnet, rlogin, rsh, etc.
- SSHv1 deprecated, SSHv2 current
 - Offers also secure file transfer using SCP
- [TCP on port 22](#)
- Asymmetric cryptography
- Guarantees
 - Authentication of both parties
 - Confidentiality of data transfer (nobody can read it)
 - Integrity of messages (nobody can alter it)

- SSH is organized as three protocols that typically run on top of TCP
- **SSH Transport Layer Protocol**
 - It is responsible for server authentication, confidentiality and integrity, compression.
- **SSH User Authentication Protocol**
 - It is responsible for client (user) authentication to the server.
- **SSH Connection Protocol**
 - It multiplexes the encrypted tunnel into several logical channels.

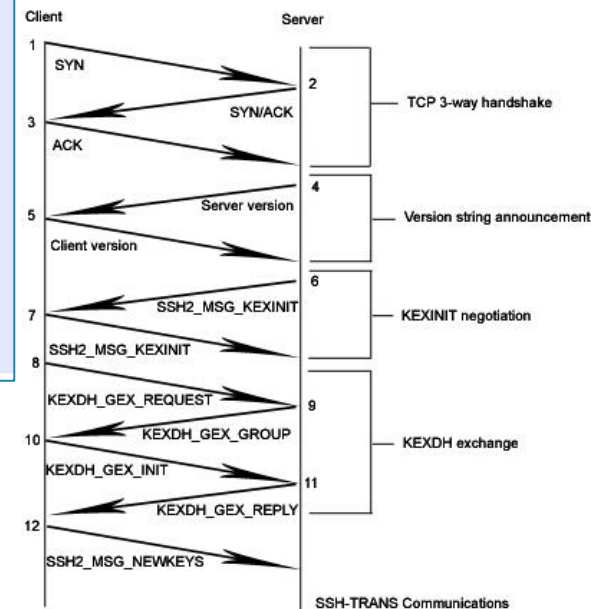
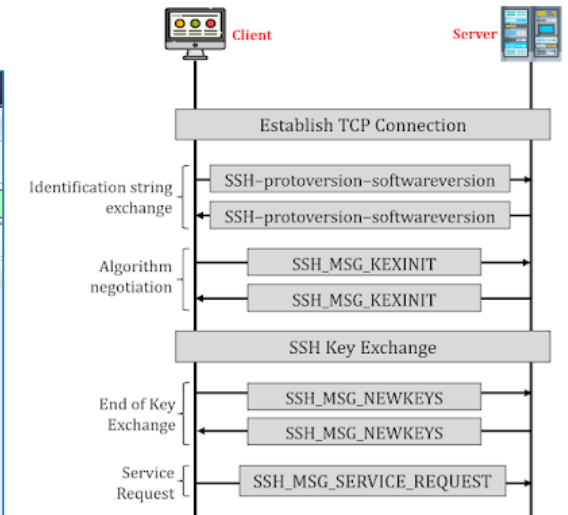


- **Packet length**
 - Length of the packet in bytes, not including the packet length and MAC fields.
- **Padding length**
 - Length of the random padding field.
- **Payload**
 - Useful contents of the packet. Prior to algorithm negotiation, this field is uncompressed. If compression is negotiated, then in subsequent packets, this field is compressed.
- **Random padding**
 - Once an encryption algorithm has been negotiated, this field is added. It contains random bytes of padding so that that total length of the packet (excluding the MAC field) is a multiple of the cipher block size, or 8 bytes for a stream cipher.
- **Message authentication code (MAC)**
 - If message authentication has been negotiated, this field contains the MAC value. The MAC value is computed over the entire packet plus a sequence number, excluding the MAC field. The sequence number is an implicit 32-bit packet sequence that is initialized to zero for the first packet and incremented for every packet. The sequence number is not included in the packet sent over the TCP connection.



pctl = packet length
pdl = padding length

*Local Area Connection				
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help				
ssh				
No.	Source	Destination	Protocol	Info
...	192.168.0.6	192.168.0.23	SSHv2	Client: Protocol (SSH-2.0-PuTTY_Release_0.65)
...	192.168.0.23	192.168.0.6	SSHv2	Server: Protocol (SSH-2.0-OpenSSH_6.6.1)
...	192.168.0.6	192.168.0.23	SSHv2	Client: Key Exchange Init
...	192.168.0.23	192.168.0.6	SSHv2	Server: Key Exchange Init
...	192.168.0.6	192.168.0.23	SSHv2	Client: Diffie-Hellman Group Exchange Request
...	192.168.0.23	192.168.0.6	SSHv2	Server: Diffie-Hellman Group Exchange Group
...	192.168.0.6	192.168.0.23	SSHv2	Client: Diffie-Hellman Group Exchange Init
...	192.168.0.23	192.168.0.6	SSHv2	Server: Diffie-Hellman Group Exchange Reply, New Keys
...	192.168.0.6	192.168.0.23	SSHv2	Client: New Keys
...	192.168.0.6	192.168.0.23	SSHv2	Client: Encrypted packet (len=64)
...	192.168.0.23	192.168.0.6	SSHv2	Server: Encrypted packet (len=64)
...	192.168.0.6	192.168.0.23	SSHv2	Client: Encrypted packet (len=80)
...	192.168.0.23	192.168.0.6	SSHv2	Server: Encrypted packet (len=96)
...	192.168.0.6	192.168.0.23	SSHv2	Client: Encrypted packet (len=112)
...	192.168.0.23	192.168.0.6	SSHv2	Server: Encrypted packet (len=96)
...	192.168.0.6	192.168.0.23	SSHv2	Client: Encrypted packet (len=304)
...	192.168.0.23	192.168.0.6	SSHv2	Server: Encrypted packet (len=48)
...	192.168.0.6	192.168.0.23	SSHv2	Client: Encrypted packet (len=80)
...	192.168.0.23	192.168.0.6	SSHv2	Server: Encrypted packet (len=64)
...	192.168.0.6	192.168.0.23	SSHv2	Client: Encrypted packet (len=112)
...	192.168.0.23	192.168.0.6	SSHv2	Server: Encrypted packet (len=160)
...	192.168.0.6	192.168.0.23	SSHv2	Client: Encrypted packet (len=64)
...	192.168.0.23	192.168.0.6	SSHv2	Server: Encrypted packet (len=112)
...	192.168.0.6	192.168.0.23	SSHv2	Client: Encrypted packet (len=96)



Cipher	
3des-cbc*	Three-key 3DES in CBC mode
blowfish-cbc	Blowfish in CBC mode
twofish256-cbc	Twofish in CBC mode with a 256-bit key
twofish192-cbc	Twofish with a 192-bit key
twofish128-cbc	Twofish with a 128-bit key
aes256-cbc	AES in CBC mode with a 256-bit key
aes192-cbc	AES with a 192-bit key
aes128-cbc**	AES with a 128-bit key
Serpent256-cbc	Serpent in CBC mode with a 256-bit key
Serpent192-cbc	Serpent with a 192-bit key
Serpent128-cbc	Serpent with a 128-bit key
arcfour	RC4 with a 128-bit key
cast128-cbc	CAST-128 in CBC mode

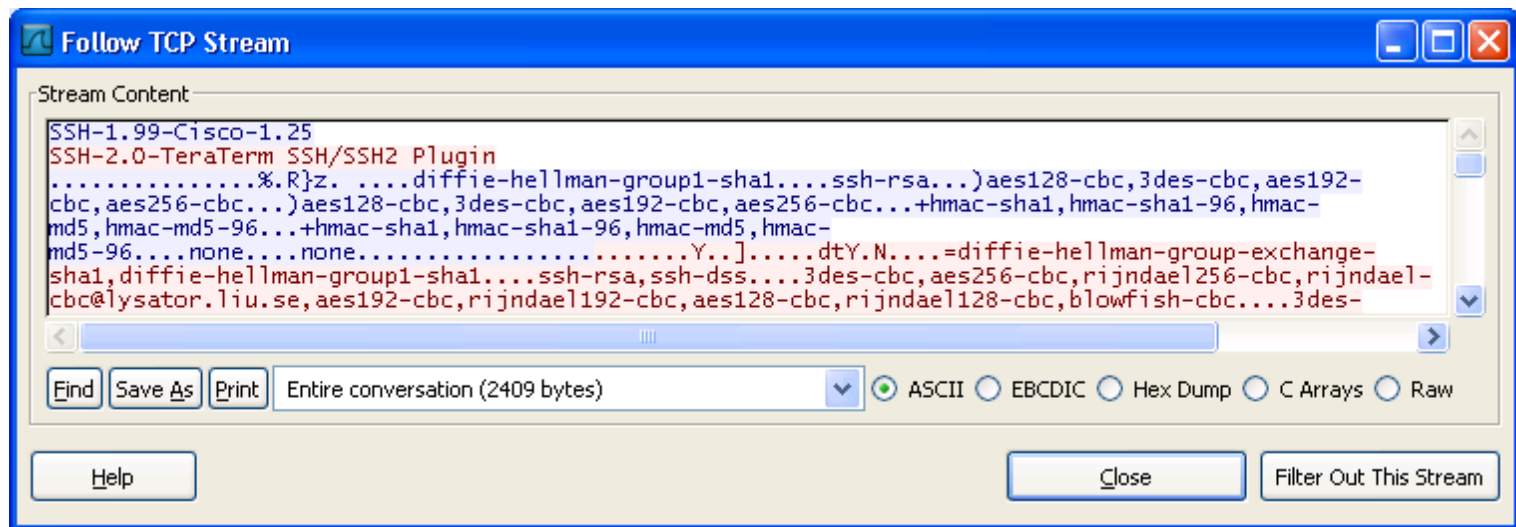
* = Required

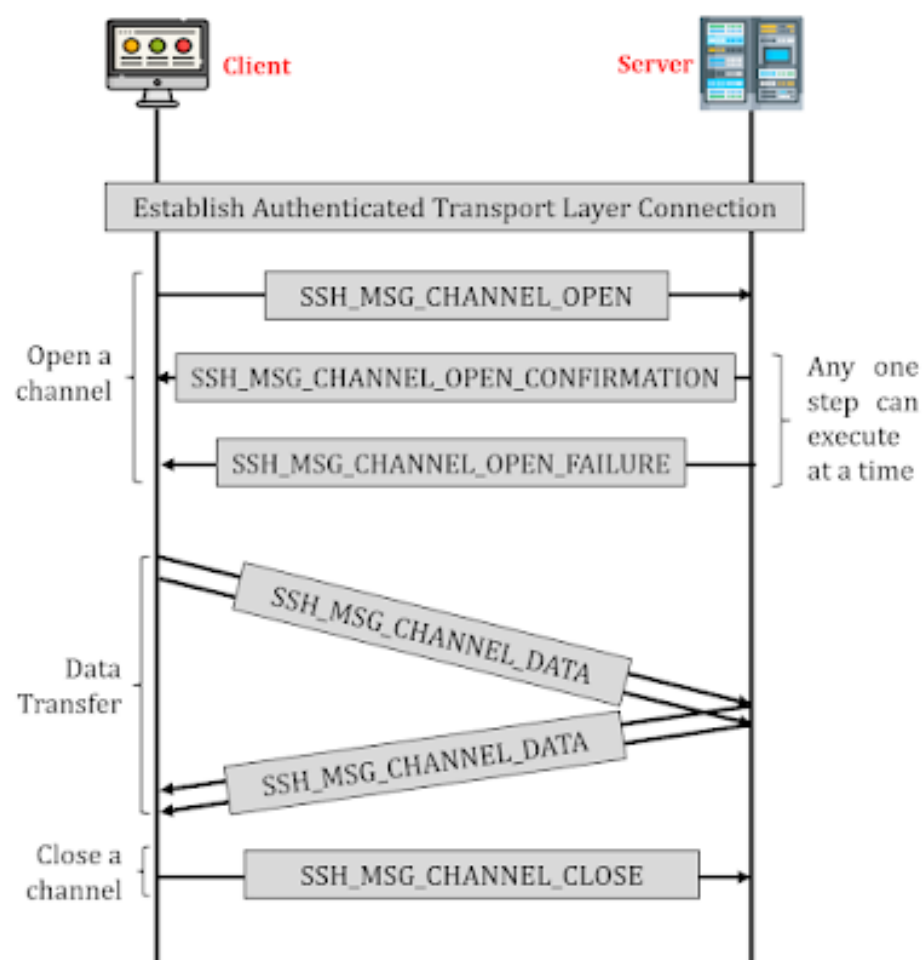
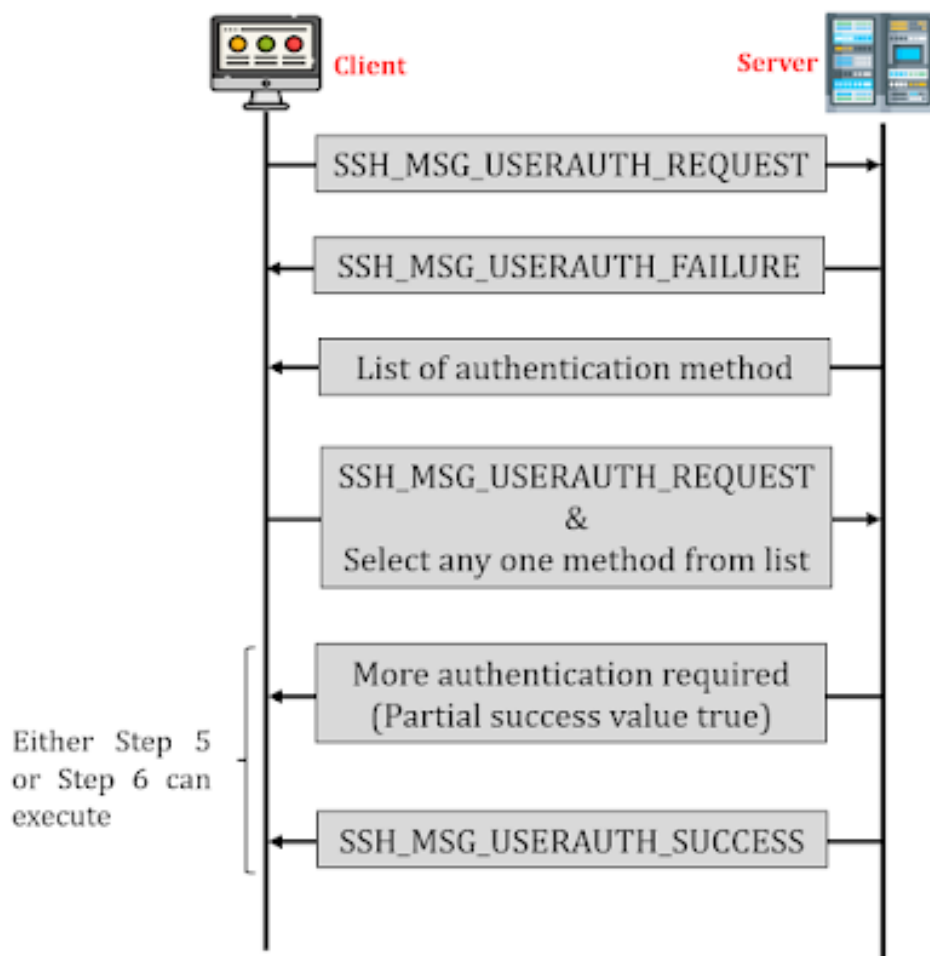
** = Recommended

MAC algorithm	
hmac-sha1*	HMAC-SHA1; digest length = key length = 20
hmac-sha1-96**	First 96 bits of HMAC-SHA1; digest length = 12; key length = 20
hmac-md5	HMAC-MD5; digest length = key length = 16
hmac-md5-96	First 96 bits of HMAC-MD5; digest length = 12; key length = 16

Compression algorithm	
none*	No compression
zlib	Defined in RFC 1950 and RFC 1951

- When following the stream of data, the attacker only sees TCP and SSH packets which reveal useless encrypted information.

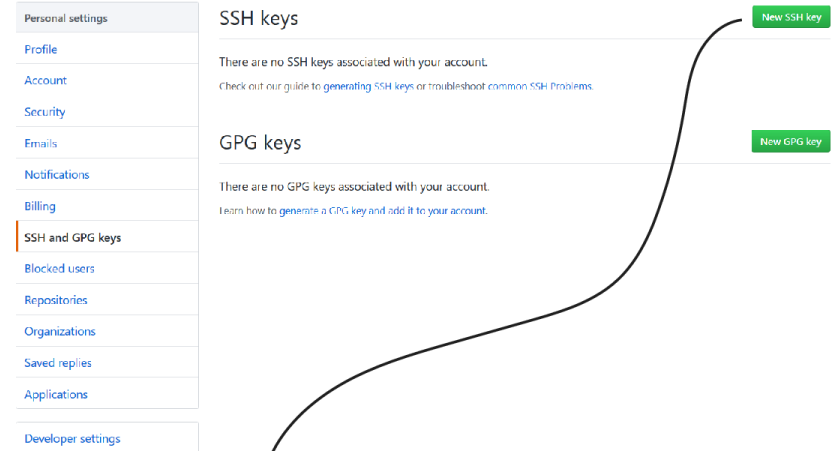




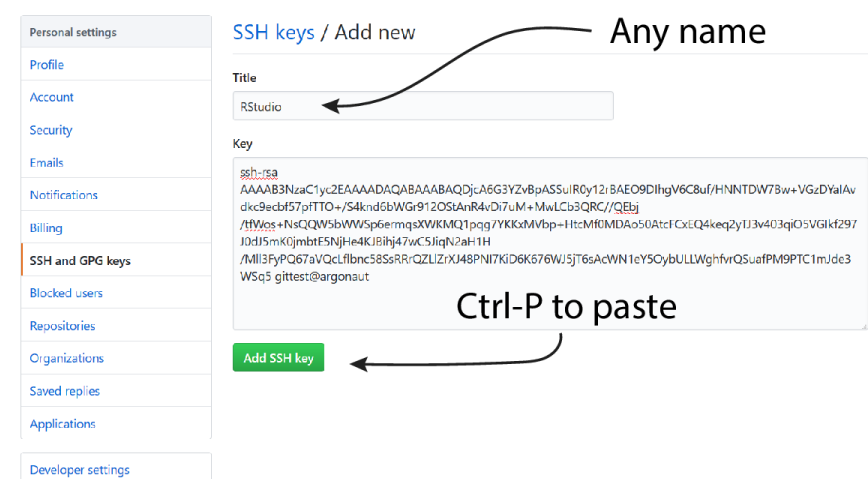
- SSH keys provide secure, passwordless authentication between client and server.
- Consist of two keys
 - Public and Private
- How it works?
 - 1) Generate key pair (`ssh-keygen`)
 - 2) Public key is copied to server (`authorized_keys` file)
 - 3) Private key stays secure on the client
 - 4) Server verifies client identity using keys instead of passwords
- Benefits
 - Enhanced security (resistant to brute-force attacks).
 - Improved convenience for automation and scripting.
 - Easier key revocation and management.

github.com -> Settings -> SSH and GPG keys

A



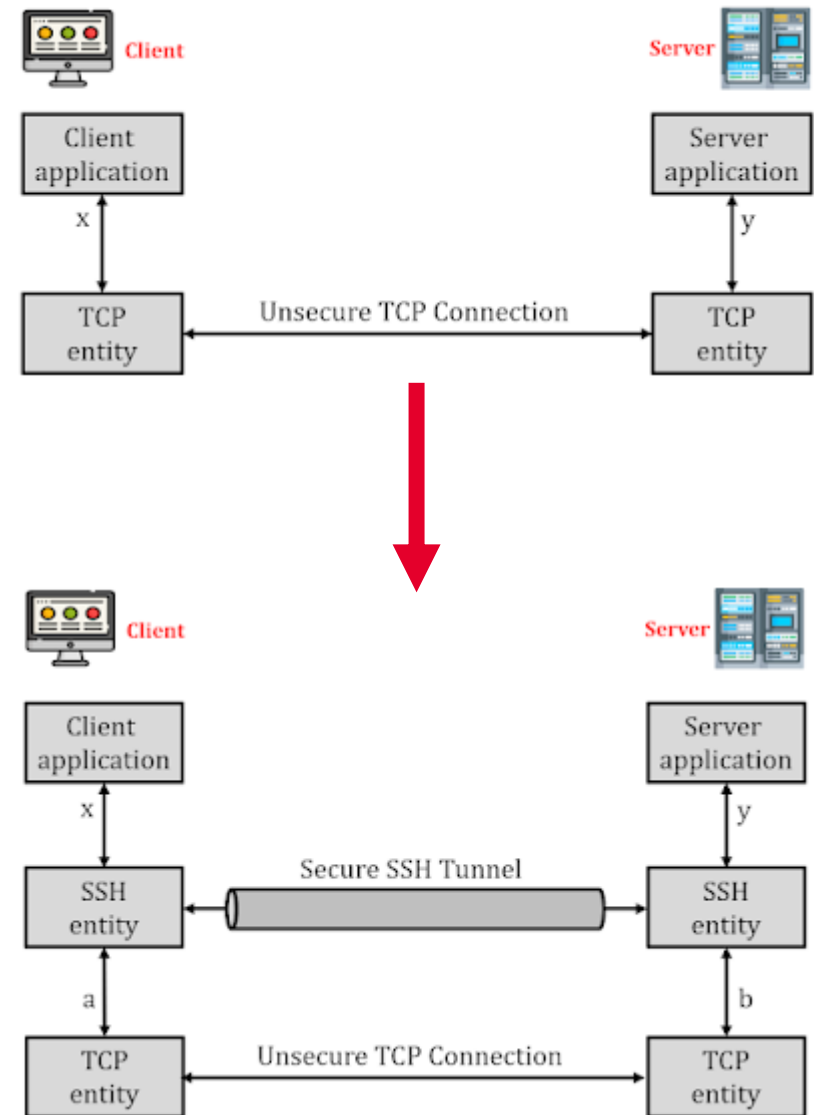
B

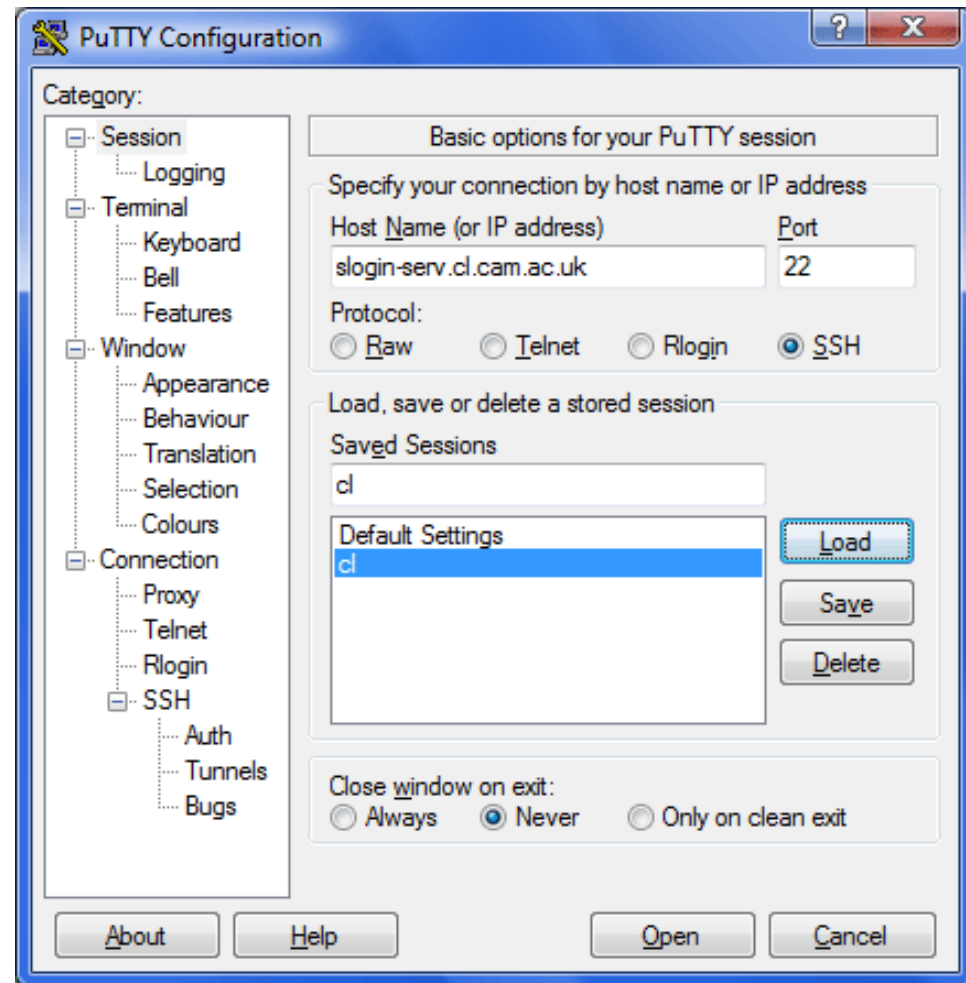


- **Port forwarding** provides the ability to convert any insecure TCP connection into a secure SSH connection.
- Local/Remote PF

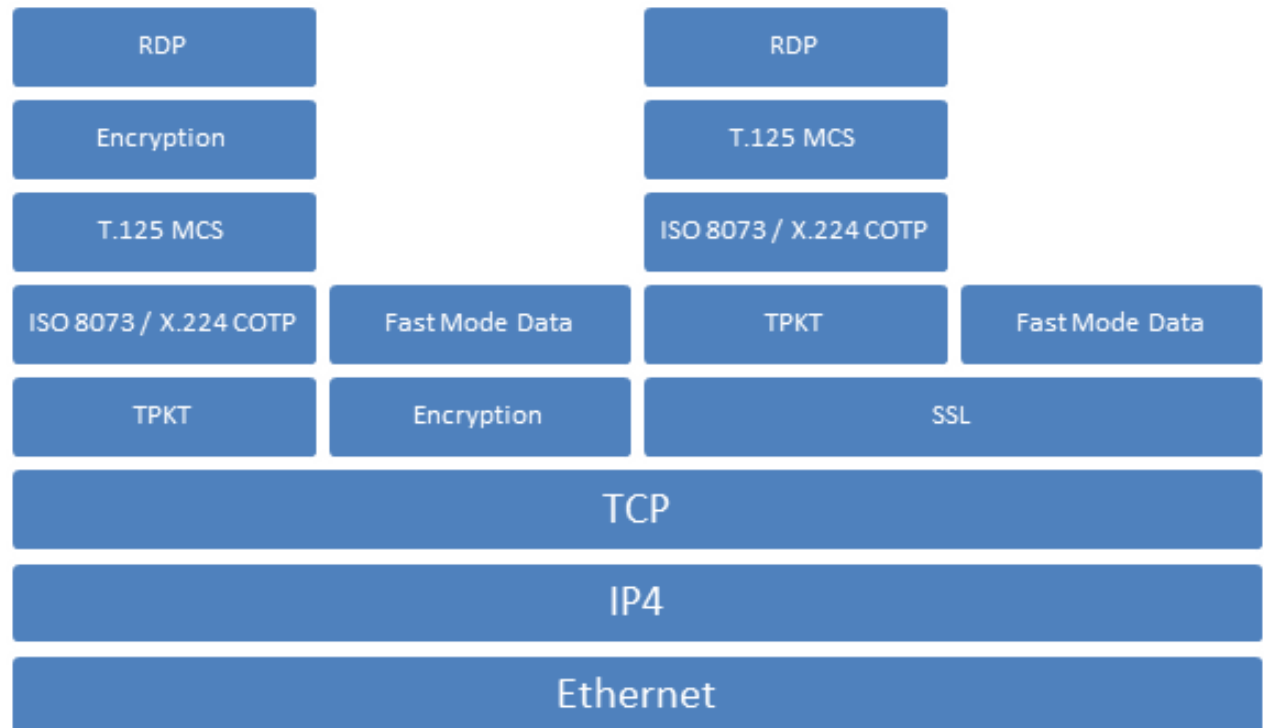
```
ssh -L local_port:remote_host:remote_port user@ssh_server
```

```
ssh -R remote_port:local_host:local_port user@ssh_server
```

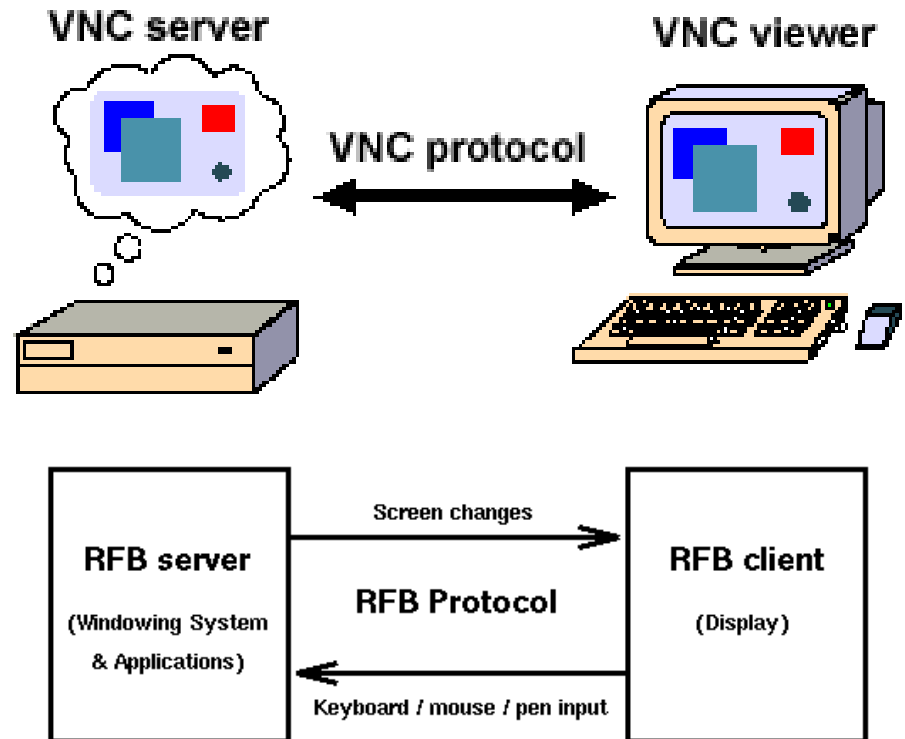


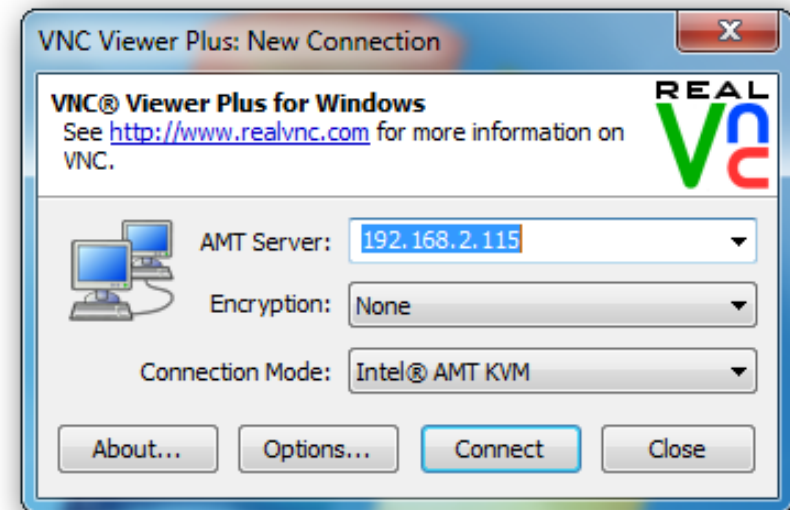
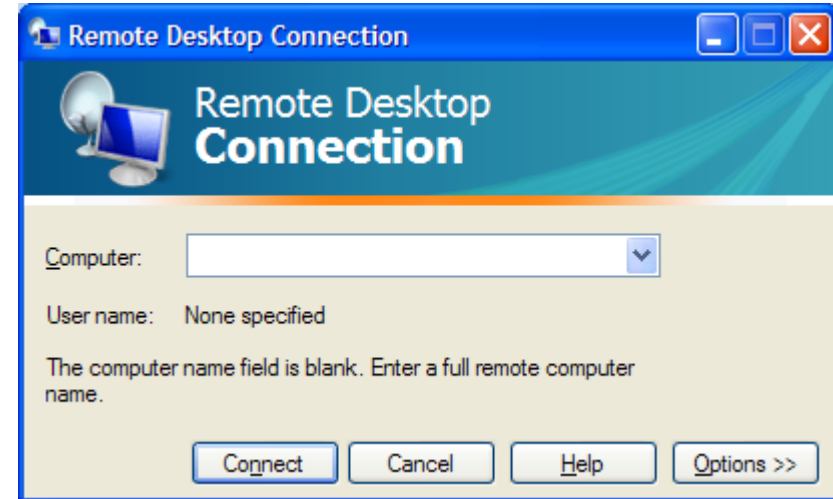
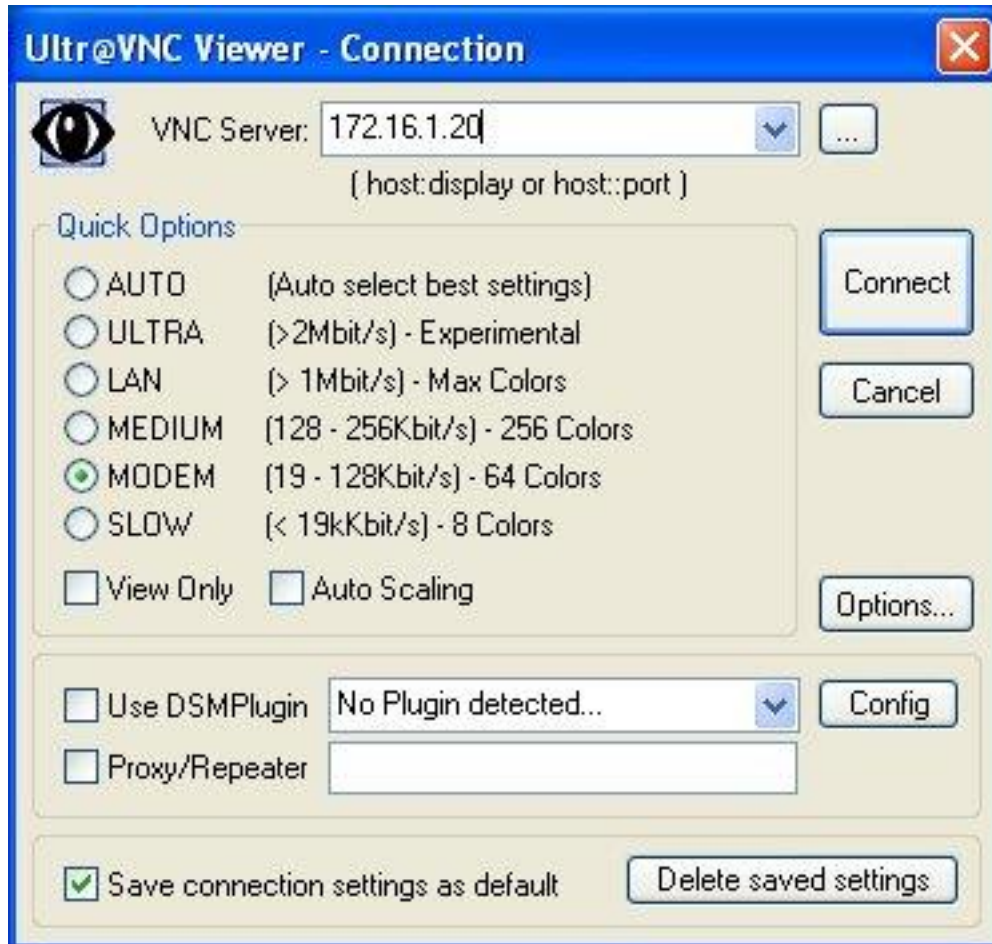


- Microsoft proprietary protocol
- Windows: mstsc
- Unix: rdesktop
- TCP port 3389



- Graphical desktop sharing system that uses Remote Frame Buffer (RFB)
 - RFB v3.8 by a RealVNC from 2010
- Pixel based
- TCP port 5900
- <http://www.realvnc.com/docs/rfbproto.pdf>





Q & A

- What does AAA stands for? What is accounting?
- Explain 802.1x and EAP in detail.
- What protocols are used for AAA on the use-case of network infrastructure?
- Describe SSH protocol. Which port is default for SSH server?
- What is difference and usage of SSH Transport Layer / User Authentication / Connection protocol?
- What user authentication methods can be used when leveraging SSH for the remote access?
- What is a difference between remote desktop and VNC protocols?

- <https://www.chiragbhalodia.com/2022/05/ssh-and-ssh-protocol-stack.html>
- <https://www.cloudflare.com/learning/access-management/what-is-ssh/>
- <https://www.digitalocean.com/community/tutorials/understanding-the-ssh-encryption-and-connection-process>

Vladimír Veselý veselyv@fit.vut.cz



- výzkumná skupina NES@FIT = specializace NNET
 - <https://www.fit.vut.cz/research/groups/nes@fit/>
- repa s různými projekty
 - <https://nesfit.github.io>
 - <https://git.fit.vutbr.cz/NESFIT>